Phenikaa University — Faculty of Information Technology

CSE703153

Hướng dẫn Viết Báo cáo Đồ án

Kỹ thuật Lập trình An toàn (Software Security)

Cấu trúc bắt buộc, định dạng, mẫu bảng before/after,
tiêu chí chấm điểm và danh sách kiểm tra trước khi nộp

Năm học 2026–2027

Giảng viên: MSc. Vũ Quang Dũng
Đơn vị: Trường Công nghệ Thông tin — Đại học Phenikaa

Tài liệu này áp dụng cho cả 5 đề tài trong *Hướng dẫn Đề tài Đồ án Môn học* (`Huong_dan_De_tai_Do_an_Mon_hoc.pdf`).

Contents

1 Mục đích và phạm vi **2**

2 Cấu trúc báo cáo bắt buộc **2**

3 Định dạng và trình bày **2**
3.1 Yêu cầu định dạng chung . . . 3
3.2 Trích dẫn CWE/CERT . . . 3
3.3 Quy ước đặt tên phiên bản mã nguồn . . . 3
3.4 Quy ước commit (nếu nộp kèm lịch sử Git) . . . 3

4 Hướng dẫn viết chi tiết từng phần **3**
4.1 Phần 2 — Tổng quan đề tài . . . 3
4.2 Phần 3 — Phương pháp luận . . . 4
4.3 Phần 4 — Phân tích lỗ hổng & Bản vá . . . 4
4.3.1 Ví dụ minh hoạ (trích từ Đề tài 1) . . . 4
4.4 Phần 6 — Bằng chứng kiểm chứng . . . 5
4.5 Phần 7 — Phản biện & Bài học . . . 5

5 Mẫu bảng và trang chuẩn **5**
5.1 Mẫu bảng tổng hợp before/after (Phần 5, bắt buộc) . . . 5
5.2 Mẫu trang bìa . . . 6
5.3 Mẫu mục lục tối thiểu . . . 6

6 Tiêu chí chấm điểm báo cáo **6**

7 Những lỗi thường gặp cần tránh khi viết báo cáo **7**

8 Danh sách kiểm tra trước khi nộp **7**

1 Mục đích và phạm vi

Tài liệu này quy định **cấu trúc bắt buộc**, **định dạng trình bày**, **cách viết từng phần**, và **tiêu chí chấm điểm** cho báo cáo đồ án môn học, áp dụng thống nhất cho cả 5 đề tài mô tả trong *Hướng dẫn Đề tài Đồ án Môn học*. Mục tiêu của báo cáo không phải là kể lại những gì đã làm, mà là **chứng minh bằng bằng chứng công cụ** rằng từng lỗ hổng đã được xác nhận tồn tại và sau đó đã được loại bỏ — đúng tinh thần "trust, but verify" đã được nhấn mạnh xuyên suốt môn học và minh hoạ trong `REPORT.md` mẫu của `Project_Secure_CPP_Capstone.pdf`.

Lưu ý / Lỗi thường gặp

Một báo cáo mô tả đúng lý thuyết CWE/CERT nhưng **không có bằng chứng công cụ trước/sau** (log sanitizer, log static-analysis, log kịch bản tấn công) sẽ bị coi là *không đạt* tiêu chí "Chất lượng bằng chứng" (20% tổng điểm, xem Mục 2 của Hướng dẫn Đề tài), bất kể phần mô tả lý thuyết hay đến đâu.

2 Cấu trúc báo cáo bắt buộc

Báo cáo gồm 8 phần bắt buộc theo đúng thứ tự dưới đây. Không đổi tên, không gộp, không đảo thứ tự các phần (thứ tự này giúp việc chấm bài nhất quán giữa các nhóm).

#	Tên phần	Nội dung chính	Độ dài gợi ý
1	Trang bìa & Thông tin nhóm	Tên đề tài, thành viên, MSSV, lớp, giảng viên	1 trang
2	Tổng quan đề tài	Mô tả bài toán, kiến trúc, phạm vi đã/không thực hiện	1–1.5 trang
3	Phương pháp luận	Quy trình 5 bước áp dụng, công cụ sử dụng, cách sinh dữ liệu	1 trang
4	Phân tích lỗ hổng & Bản vá	Từng CWE: vị trí, nguyên nhân, cách vá, đoạn mã trước/sau	3–6 trang
5	Bảng tổng hợp before/after	Bảng chuẩn hoá toàn bộ lỗ hổng và trạng thái	1 trang
6	Bằng chứng kiểm chứng	Log công cụ, ảnh chụp, số liệu trước/sau	1–3 trang (phụ lục)
7	Phản biện & Bài học	Hạn chế còn lại, điều sẽ làm khác nếu bắt đầu lại	0.5–1 trang
8	Phụ lục	Log đầy đủ, hướng dẫn build, phân công công việc	không giới hạn

Table 1: Cấu trúc báo cáo bắt buộc, 8 phần.

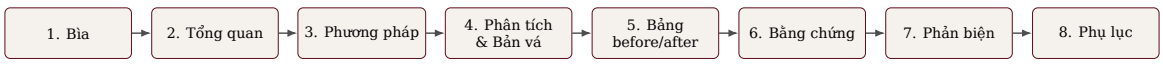


Figure 1: Trình tự 8 phần bắt buộc của báo cáo.

3 Định dạng và trình bày

3.1 Yêu cầu định dạng chung

- Định dạng file nộp: PDF (khuyến nghị biên dịch từ LaTeX hoặc Word/Google Docs xuất PDF); không nộp file `.docx`/`.md` thô.
- Font chữ: một font có hỗ trợ tiếng Việt có dấu đầy đủ (Times New Roman, hoặc DejaVu Serif nếu dùng LaTeX như tài liệu này); cỡ chữ 11–12pt cho văn bản thường.
- Lề trang: tối thiểu 2 cm mỗi bên; đánh số trang liên tục.
- Đoạn mã nguồn trích dẫn trong báo cáo: dùng font đơn cách (monospace), có đánh số dòng nếu đoạn dài hơn 10 dòng, và phải ghi rõ tên file + số dòng gốc trong mã nguồn nộp kèm.
- Ảnh chụp màn hình (terminal, trình duyệt): phải đọc được rõ ràng ở cỡ in ấn bình thường (không phóng to quá mức làm vỡ nét chữ); mọi ảnh phải có chú thích (caption) giải thích đây là bằng chứng cho lỗi/bản vá nào.

3.2 Trích dẫn CWE/CERT

Mỗi khi nhắc tới một lỗ hổng, **luôn đi kèm mã CWE cụ thể** (không viết chung chung "lỗi bảo mật"), theo mẫu:

`CWE-120 (Buffer Copy without Checking Size of Input) tại hàm set_source`

Nếu bài giảng có nhắc tới quy tắc CERT tương ứng (ví dụ STR31-C, MEM31-C, CON43-C, INT30-C), nên trích dẫn kèm theo để thể hiện đã hiểu đúng ngữ cảnh chuẩn hoá của lỗi, không chỉ dừng ở việc tra CWE.

3.3 Quy ước đặt tên phiên bản mã nguồn

- Giữ nguyên file `*_v0.*` như được cấp phát — **không sửa trực tiếp** lên file này.
- Đặt tên file đã vá là `*_v1.*` (hoặc tăng dần `v2, v3, ...` nếu vá theo nhiều đợt, mỗi đợt tương ứng một milestone).
- Trong báo cáo, mọi đoạn mã trích dẫn phải ghi rõ đến từ phiên bản nào (`v0` hay `v1`).

3.4 Quy ước commit (nếu nộp kèm lịch sử Git)

Listing 1: Mẫu commit message — mỗi lớp lỗi một commit riêng

```
fix(CWE-120): bounded copy in set_source/set_message

- Replace strcpy() with strnlen()+bounded memcpy() pattern
- Reject oversized input instead of silently truncating
- Add regression test: test_oversized_source_rejected

Verified: ASan clean on logs_malicious.txt (0 findings, was: 1 SEGV)
```

4 Hướng dẫn viết chi tiết từng phần

4.1 Phần 2 — Tổng quan đề tài

- Nêu tên đề tài đã chọn (trong 5 đề tài ở Mục 3 của Hướng dẫn Đề tài), ngôn ngữ, và các tuần học liên quan.

- Mô tả ngắn gọn chức năng của hệ thống `v0` (2–4 câu) — không cần chép lại nguyên văn phần mô tả trong tài liệu đề tài, hãy diễn đạt lại bằng lời của nhóm để thể hiện đã hiểu bài toán.
- Vẽ lại (hoặc chèn lại có trích dẫn nguồn) sơ đồ kiến trúc của đề tài, đánh dấu rõ những phần nhóm đã thay đổi so với `v0`.
- Nêu rõ phạm vi: những CWE nào đã vá hoàn toàn, những CWE nào (nếu có) chưa vá được và lý do.

4.2 Phần 3 — Phương pháp luận

- Liệt kê các công cụ đã dùng: trình biên dịch + cờ biên dịch, sanitizer (ASan/UBSan/TSan), công cụ phân tích tĩnh (cppcheck/clang-tidy), hoặc harness kiểm thử tấn công (đối với Đề tài 4).
- Nêu rõ cách dùng script `data_gen/` của đề tài: tham số đã chạy (`--seed`, số lượng bản ghi), và vì sao chọn các tham số đó.
- Nếu nhóm có tự viết thêm harness/test ngoài những gì được cấp sẵn, mô tả ngắn gọn cách harness đó hoạt động.

4.3 Phần 4 — Phân tích lỗ hổng & Bản vá

Đây là phần trọng tâm, chiếm tỷ trọng lớn nhất của báo cáo. Với **mỗi** CWE đã vá, trình bày theo đúng 5 mục con sau (dùng lại đúng cấu trúc này cho từng lỗ hổng):

1. **Vị trí & mô tả**: tên hàm/file, số dòng trong `v0`.
2. **Nguyên nhân gốc rễ**: giải thích bằng lý thuyết đã học (ví dụ: vì sao `strcpy` không kiểm tra biên đích, không phải chỉ nói ”hàm này không an toàn”).
3. **Bằng chứng lỗi tồn tại**: trích đoạn log sanitizer/công cụ, hoặc mô tả kịch bản tấn công thành công, kèm tham chiếu tới file log đầy đủ trong Phụ lục.
4. **Cách vá**: đoạn mã trước (`v0`) và sau (`v1`) đặt cạnh nhau, giải thích vì sao cách vá này loại bỏ triệt để nguyên nhân gốc rễ (không chỉ ”làm im” triệu chứng).
5. **Bằng chứng đã vá**: log công cụ chạy lại trên `v1`, cho thấy 0 finding hoặc kịch bản tấn công không còn thành công.

Gợi ý thực hiện

Dùng định dạng ”trước/sau” song song (hai cột hoặc hai khối liền kề) cho đoạn mã – điều này giúp người chấm bài xác nhận nhanh sự thay đổi mà không phải lật qua lật lại giữa các trang.

4.3.1 Ví dụ minh hoạ (trích từ Đề tài 1)

Listing 2: Trước (v0) — CWE-120

```
int set_source(log_entry_t *e, const char *source) {
   strcpy(e->source, source); /* khong kiem tra bien */
   return 0;
}
```

Listing 3: Sau (v1) — đã vá

```c
int set_source(log_entry_t *e, const char *source) {
   size_t len = strnlen(source, SOURCE_MAX);
   if (len >= SOURCE_MAX) return -1; /* tu choi thay vi cat bot am tham */
   memcpy(e->source, source, len);
   e->source[len] = '\0';
   return 0;
}
```

Listing 4: Bằng chứng trước/sau (trích log ASan)

```
[BEFORE] ==12345==ERROR: AddressSanitizer: stack-buffer-overflow
       WRITE of size 200 at 0x7ffee... thread T0
       #0 in set_source src/logserver_v0.c:34

[AFTER] All enabled tests passed. (0 sanitizer findings)
```

4.4 Phần 6 — Bằng chứng kiểm chứng

- Đặt log đầy đủ (không cắt bớt) trong phụ lục, chỉ trích đoạn quan trọng nhất vào Phần 4.
- Với Đề tài 2 và 3, bắt buộc có bảng số liệu tổng hợp số lần chạy công cụ (ví dụ: ”chạy 5 lần với seed khác nhau, 0/5 lần có race report”).
- Với Đề tài 3, bắt buộc có bảng số lượng cảnh báo `cppcheck`/ `clang-tidy` trước và sau.

4.5 Phần 7 — Phản biện & Bài học

Trả lời ngắn gọn (mỗi câu 2–4 câu) các câu hỏi sau:

- Nếu bắt đầu lại từ đầu, nhóm sẽ thiết kế lại phần nào để tránh lỗ hổng ngay từ đầu (thay vì vá sau)?
- Có lỗ hổng nào nhóm nghi ngờ vẫn còn tồn tại nhưng chưa đủ thời gian/công cụ để xác nhận không?
- Bài học lớn nhất về phương pháp luận (không phải về cú pháp ngôn ngữ) mà nhóm rút ra được?

5 Mẫu bảng và trang chuẩn

5.1 Mẫu bảng tổng hợp before/after (Phần 5, bắt buộc)

Đây là bảng **quan trọng nhất** của báo cáo — người chấm bài thường đọc bảng này đầu tiên để nắm toàn bộ phạm vi công việc trước khi đọc chi tiết Phần 4.

Lưu ý / Lỗi thường gặp

Cột ”Trạng thái v0” và ”Trạng thái v1” phải là **mô tả có thể kiểm chứng được** (ví dụ: tên lỗi sanitizer cụ thể, số dòng log, hoặc kết quả kịch bản tấn công), không được viết chung chung như ”có lỗi” / ”đã sửa”.

CWE	Vị trí	Trạng thái v0	Trạng thái v1	Công cụ xác minh
CWE-120	`set_source`	Stack buffer overflow, ASan SEGV	Từ chối input quá khổ, 0 finding	ASan
CWE-134	`print_entry`	Format string in được payload `%n`	Chuỗi định dạng cố định, payload vô hại	Kiểm thử thủ công + ASan
—	—	—	—	—

Table 2: Mẫu bảng before/after — điền đầy đủ một dòng cho mỗi CWE đã vá của đề tài đã chọn.

5.2 Mẫu trang bìa

TRƯỜNG CÔNG NGHỆ THÔNG TIN — ĐẠI HỌC PHENIKAA

BÁO CÁO ĐỒ ÁN MÔN HỌC
CSE703153 — Kỹ thuật Lập trình An toàn

Đề tài: *[Tên đề tài đã chọn trong 5 đề tài]*

Nhóm: [Số nhóm] Lớp: [Mã lớp]
Thành viên: [Họ tên — MSSV], [Họ tên — MSSV], ...
Giảng viên hướng dẫn: [Họ tên]

Hà Nội, [Tháng, Năm]

5.3 Mẫu mục lục tối thiểu

1. Tổng quan đề tài
2. Phương pháp luận
3. Phân tích lỗ hổng & Bản vá
   (a) CWE-XXX tại `tên_hàm_1`
   (b) CWE-YYY tại `tên_hàm_2`
   (c) ...(một mục con cho mỗi CWE đã vá)
4. Bảng tổng hợp before/after
5. Bằng chứng kiểm chứng
6. Phản biện & Bài học
7. Phụ lục

6 Tiêu chí chấm điểm báo cáo

7 Những lỗi thường gặp cần tránh khi viết báo cáo

Tiêu chí	Mô tả cụ thể	Trọng số
Đầy đủ cấu trúc 8 phần	Không thiếu, không đảo thứ tự, đúng tên các phần theo Mục 2.	10%
Chất lượng phân tích lỗ hổng (Phần 4)	Mỗi CWE được trình bày đủ 5 mục con (vị trí, nguyên nhân, bằng chứng trước, cách vá, bằng chứng sau); giải thích đúng nguyên nhân gốc rễ, không chỉ mô tả triệu chứng.	35%
Bảng before/after (Phần 5)	Đầy đủ mọi CWE đã vá, mô tả có thể kiểm chứng, khớp với nội dung Phần 4.	15%
Chất lượng bằng chứng (Phần 6)	Log đầy đủ, không bị cắt xén gây khó hiểu, có chú thích rõ ràng cho từng ảnh/log.	20%
Chiều sâu phản biện (Phần 7)	Trả lời trung thực, có chiều sâu, không sáo rỗng.	10%
Định dạng & trình bày	Tuân thủ Mục 3 của tài liệu này (font, trích dẫn CWE, đặt tên phiên bản mã nguồn).	10%

Table 3: Tiêu chí chấm điểm báo cáo (độc lập với tiêu chí chấm mã nguồn ở Hướng dẫn Đề tài, Mục 2.2).

Lưu ý / Lỗi thường gặp

- **Chỉ mô tả CWE bằng lời, không có log/ảnh chụp kèm theo.** Đây là lỗi phổ biến nhất và bị trừ điểm nặng nhất (thuộc tiêu chí ”Chất lượng bằng chứng”, 20%).
- **Copy nguyên văn định nghĩa CWE từ trang MITRE mà không giải thích áp dụng cụ thể vào đề tài như thế nào.**
- **Đoạn mã ”trước” và ”sau” giống hệt nhau** (quên cập nhật ví dụ khi chỉnh sửa báo cáo ở phút chót) — luôn kiểm tra lại trước khi nộp.
- **Bảng before/after ở Phần 5 không khớp với các CWE đã phân tích ở Phần 4** (thiếu dòng, hoặc liệt kê CWE chưa từng được nhắc tới).
- **Nộp log dài hàng trăm dòng không có chú thích**, khiến người chấm không biết cần nhìn vào đâu — luôn tô đậm/trích dẫn đúng dòng quan trọng.
- **Phần phản biện chỉ có 1 câu chung chung** (”chúng em đã học được nhiều điều”) — cần cụ thể, gắn với đề tài đã làm.

8 Danh sách kiểm tra trước khi nộp

Checklist nộp bài

☐ Báo cáo có đủ 8 phần theo đúng thứ tự ở Mục 2?

☐ Mọi CWE nhắc tới đều có mã số cụ thể (CWE-XXX), không viết chung chung?

☐ Mỗi CWE ở Phần 4 có đủ 5 mục con (vị trí, nguyên nhân, bằng chứng trước,

cách vá, bằng chứng sau)?

- ☐ Bảng before/after ở Phần 5 khớp 1–1 với các CWE đã phân tích ở Phần 4?
- ☐ Mọi log/ảnh chụp trong Phần 6 đều có chú thích rõ ràng?
- ☐ File `*_v0.*` trong mã nguồn nộp kèm còn nguyên vẹn, chưa bị sửa?
- ☐ Mã nguồn đã vá build thành công từ đầu bằng `Makefile`/hướng dẫn build?
- ☐ Đã chạy lại `data_gen` với `--seed` đã ghi trong báo cáo và kết quả khớp với log đã nộp?
- ☐ Phần phản biện (Phần 7) đã được viết cụ thể, không sáo rỗng?
- ☐ File PDF nộp mở được, không lỗi font, không thiếu trang?